



File No.: EXP202210818 (PS/00670/2022)

SANCTIONING PROCEDURE RESOLUTION

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Ms. A.A.A. (hereinafter, the complainant), on September 12, 2022, filed a complaint with the Spanish Agency for Data Protection. The complaint is directed against GEOPOST ESPAÑA, S.L. (the absorbing company of the dissolved SEUR, S.A.), with NIF B85645349, (hereinafter, GEOPOST). The reasons on which the complaint is based are as follows:

The complainant states that GEOPOST was responsible for collecting a product from Amazon at the address ***ADDRESS.1, on August 29, 2022. However, Amazon incorrectly indicated the address since at that time the complainant was in ***LOCATION.1.

On August 29, 2022, the complainant requested Amazon to modify the address.

On September 6, 2022, the complainant learned through some relatives who passed by the residence that a delivery person from the complained company had left a notice outside the mailbox of her residence in ***LOCATION.2, visible to any neighbor or visitor of the property, which contained her personal data, specifically her name and surname, postal address, as well as her phone number. This label was exposed in a passageway until September 6, 2022, the date on which it was removed. Along with the complaint, she provides a copy of the message received in her email regarding the date of collection of the package, sent by the complained party, an email sent by Amazon to the complainant indicating the correction of the package collection address, as well as various images of the label displayed outside the mailbox of her address in ***LOCATION.2.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the complained party for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), by means of electronic notification, was received on October 17, 2022, as stated in the certificate in the file.

On November 14, 2022, a written response from the complained party was received by this Agency, in which the following is stated:

- That on August 30, 2022, a GEOPOST delivery person went to the complainant's home to carry out a collection.
- That the complainant was absent at the time of collection.
- That, consequently, the delivery person left a notice of absence stuck outside the complainant's mailbox.

Thus, after analyzing the facts, GEOPOST considers that the incident occurred as a result of human error by the delivery person, who should have left the notice of absence inside the mailbox or under the door as indicated in GEOPOST's manual and not stuck outside the mailbox.

In this regard, GEOPOST informs the AEPD that, in compliance with the obligations of the applicable regulations for its transport activity, it has implemented the corresponding procedures and corporate manuals, which establish the guidelines to be followed for the correct delivery or collection of goods. Specifically, it is indicated that GEOPOST has a manual with the operational procedures that delivery persons must follow, called the "Delivery Person Operational Manual," a document that is provided to them at the time of hiring or the start of service provision with GEOPOST. In the section "Route Operations" of this manual, it specifically states the obligation that the delivery of goods must always be made to the recipient and that, in the event of the recipient's absence, a notice of absence should be left at the residence under the door, in the door wedge, or in the mailbox. Annex I includes screenshots from the manual specifying the obligations of delivery persons for the correct delivery or collection of goods.

Additionally, it states that GEOPOST provides periodic training to delivery persons on the obligations set forth in the various procedures and corporate manuals, emphasizing the importance of making proper use and diligently handling the personal data they manage daily from senders, recipients, and/or authorized persons. Specifically, one of the latest training actions consisted of disseminating a video titled "Good Practices in Privacy."

For all these reasons, it confirms that the incident occurred due to a specific malpractice by the delivery person for not following the company's internal protocols.

However, as a consequence of the incident, GEOPOST has reiterated its commitment that all delivery persons comply with what is established in the various procedures, policies, and manuals made available to them in order to correctly carry out deliveries and returns, as well as, a

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/23

diligent action regarding personal data processed in the fulfillment of their work functions or service provision.

Finally, it indicates that GEOPOST manages a large volume of deliveries and pickups daily, with the delivery personnel properly following the company's internal protocols without any incidents similar to the subject of this complaint. Only in the year 2021, the volume managed was over 50 million deliveries and pickups, and it considers that the misconduct of the delivery person is a fact that does not resemble the usual operation.

THIRD: On December 2, 2022, in accordance with Article 65 of the LOPDGDD, the complaint filed by the claimant was admitted for processing.

FOURTH: According to the report obtained from the AXESOR tool, the defunct SEUR, S.A. (absorbed by GEOPOST ESPAÑA, S.L.) is a medium-sized company established in 1984, with a turnover of (...) € in the year 2021.

FIFTH: On May 22, 2023, the Director of the Spanish Data Protection Agency agreed to initiate sanctioning proceedings against the respondent, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of the GDPR, as well as for the alleged infringement of Article 32 of the GDPR, classified in Article 83.4 of the GDPR.

SIXTH: The aforementioned initiation agreement was notified on May 23, 2023, in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP). GEOPOST submitted a written statement of allegations in which, in summary, it stated that the incident occurred due to the misconduct of the delivery person for failing to comply with the company's internal instructions and protocols; there was no possibility of committing a violation of Article 5.1.f) without also committing an infringement of Article 32 of the GDPR, and only the sanction corresponding to the most serious infringement committed should be imposed (art. 29.4 of the LRJSP); it understands that adequate measures (protocols, periodic training plan, etc.) have been adopted based on the risk, and finally, regarding the aggravating factors, the volume of orders managed by GEOPOST and the exceptional nature of such cases have not been taken into account, nor have other circumstances been considered as mitigating factors to reduce the sanctions.

SEVENTH: On January 31, 2024, the instructing body of the procedure formulated a resolution proposal, in which it proposes that the Director of the AEPD sanction GEOPOST, with NIF B85645349, for an infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of the GDPR, with a fine of €40,000 (forty thousand euros), and for the alleged infringement of Article 32 of the GDPR, classified in Article 83.4 of the GDPR, with a fine of €15,000 (fifteen thousand euros).

This resolution proposal, which was notified to GEOPOST in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was received on February 1, 2024, as evidenced by the acknowledgment of receipt in the

file.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

4/23

EIGHTH: On February 14, 2024, this Agency received, in due time and form, a letter from GEOPOST in which it presented allegations to the resolution proposal, stating, in summary, the infringement of the right to defense due to the absence of evidence supporting the facts attributed to it.

From the actions carried out in this procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: On August 29, 2022, at 10:38 hours, AMAZON sent the claimant an email from the address (...)@amazon.es with the following content:

"Hello, A.A.A.

I hope you are having an excellent day and a great week!

You are speaking with B.B.B., customer service agent of Amazon.es, who had the pleasure of assisting you today.

I appreciate the time you kindly took to contact us so we can do everything necessary to improve the service we provide you.

Initially, I apologize for the difficulties encountered with your order; I know you deserve quality service, and I want you to know that you have nothing to worry about as you have our support on all your purchases, and the solution we seek will always be the one that benefits you the most.

As we agreed today, SEUR will pick up the package within 72 business hours.

There is no need for you to print any return label. SEUR will provide the label and attach it to the package when they come to collect the product.

Address:

A.A.A.

***ADDRESS.2

Main phone ***PHONE.1

I hope I have resolved your request; it was a pleasure to assist you today. I have done everything within my reach to provide you with the best response so that you can have the best customer service experience at Amazon.es.

[...]"

SECOND: On August 29, 2022, at 13:14 hours, GEOPOST sent the claimant an email from the address infoenvios@mail.seur.info with the following content:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

5/23

"Hello A.A.A.

The collection of your shipment is estimated today between 13:45 and 14:45 hours.

Collection Details

Shipment No.: (...)

Address: ***ADDRESS.1

THIRD: In the photographs contained in the file (pages 7 to 8), provided by the claimant along with the complaint, the exterior of a mailbox inside the entrance of a building can be observed. On the mailbox, there is a note from "SEUR," which includes personal data of the claimant, specifically, their name and surname, postal address, as well as their phone number, and as the recipient "AMAZON – returns."

In response to the transfer of the complaint dated October 17, 2022, made by this Agency, GEOPOST sent a response on November 14, 2022, in which it states that: "...after receiving this request for

information, SEUR, S.A. has proceeded to investigate the events that occurred and has verified the following:

- That on August 30, 2022, a SEUR, S.A. delivery person went to the claimant's home to make a collection.
- That the claimant was absent at the time of collection.
- That, consequently, the delivery person left a notice of absence stuck on the outside of the claimant's mailbox." (the underlining is ours)

Therefore, GEOPOST acknowledges the truthfulness of the content of the photograph provided by the claimant.

Consequently, it is considered proven that the label was affixed to the mailbox by the GEOPOST delivery person.

FOURTH: On August 3, 2023, an announcement of the merger by absorption of GEOPOST ESPAÑA, S.L. (absorbing company) and SEUR, S.A. (absorbed company) was published in the BORME.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

GEOPOST ESPAÑA, S.L. has carried out a corporate operation of merger by absorption of SEUR, S.A., according to the agreement referred to in the Proven Fact Fourth, acquiring by universal succession all rights and obligations of SEUR, S.A., which is declared extinguished. Thus, the present procedure, initiated against SEUR, S.A., continues its processing with GEOPOST ESPAÑA, S.L. as the respondent.

GEOPOST is a leading company in urgent transport and comprehensive logistics in Spain that, for the development of its activity, processes personal data, understanding personal data as: "any information about an identified or identifiable natural person."

It carries out this activity in its capacity as data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR: "data controller" or "controller": the natural or legal person, public authority, agency, or other body that, alone or jointly with others, determines the purposes and means of the processing; if the law of the Union or of the Member States determines the purposes and means of the processing, the controller or the specific criteria for its designation may be established by the law of the Union or of the Member States.

An identifiable natural person is considered to be one whose identity can be determined, directly or indirectly, in particular by means of an identifier, such as a name, an identification number, location data, an online identifier, or one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person.

Furthermore, processing should be understood as "any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination, or any other form of enabling access, comparison or interconnection, restriction, erasure, or destruction."

Article 4, section 12 of the GDPR broadly defines "personal data breaches" (hereinafter security breach) as "all...

those violations of security that result in the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data."

The reported facts materialize in the access by unauthorized third parties to personal data of the claimant due to the malpractice of a delivery person who failed to follow the internal protocols of the company.

In this case, there is a breach of personal data security under the circumstances mentioned above, categorized as a breach of confidentiality, since the defendant has exposed personal information and data without a legitimate legal basis, by leaving a notice of absence stuck on the outside of the claimant's mailbox (which only indicated the number and letter of the floor), which contained their personal data: name, surname, postal address, as well as their phone number.

According to the GT29, a "Breach of confidentiality" occurs when there is an unauthorized or accidental disclosure of personal data, or access to the same.

Within the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data is guaranteed in section 1.f) of Article 5 of the GDPR. For its part, the security of personal data is regulated in Article 32 of the GDPR, which governs the security of processing.

III

Response to the allegations made by GEOPOST regarding the initiation agreement and the allegations raised in the proposed resolution

A) Regarding the allegations made against the initiation agreement of this sanctioning procedure, a response is provided according to the order presented by GEOPOST in its writing:

"FIRST.- Regarding the issue subject to the sanctioning procedure, the receipt of the information request from the AEPD by GEOPOST and the response made by GEOPOST."

Firstly, the defendant alleges that the incident occurred due to the malpractice of the delivery person by failing to comply with the instructions and internal protocols of the company, even using a specific document (identification label of the shipment) for a purpose incompatible with that for which it was designed by GEOPOST.

In response to this allegation, it should be noted that security measures must be adopted in consideration of each and every risk present in the processing of personal data, including the human factor among them. The negligent action of the employee does not exempt GEOPOST from responsibility, as the entity responsible for the data processing now analyzed, since

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/23

according to the definition in Article 4.7 of the GDPR, is the entity that determines the purpose and means of the processing carried out.

The responsibility of the company in the sanctioning sphere for the negligent actions of an employee that result in a breach of data protection regulations has been confirmed by the jurisprudence of the Supreme Court. In this regard, it is pertinent to mention the Judgment of the Supreme Court No.

188/2022 (Contentious Chamber, Section 3), dated February 15, 2022 (rec. 7359/2020), whose Fourth Legal Foundation states:

"The fact that it was the negligent action of an employee does not exempt the entity from its responsibility as the person in charge of the correct use of the security measures that should have guaranteed the proper use of the designed data registration system. As we already stated in STS No. 196/2020, dated February 15, 2021 (rec. 1916/2020), the data controller is also liable for the actions of its employees and cannot excuse itself based on its diligent actions, separately from the actions of its employees, but rather it is the 'culpable' actions of these employees, resulting from the violation of the existing security measures, that underpins the company's responsibility in the sanctioning sphere for the 'own' acts of its employees or officials, not of third parties."

The judgment continues to argue about the responsibility of legal entities in our legal system: "...It

simply happens that, while direct liability of legal entities is admitted in our Administrative Law, which therefore recognizes their capacity to infringe, the subjective element of the infringement is manifested in these cases differently than it is for natural persons, so that, as the constitutional doctrine we have previously mentioned indicates -SsTC STC 246/1991, of December 19 (F.J. 2) and 129/2003, of June 30 (F.J. 8)- the direct reproachability derives from the legal good protected by the norm that is infringed and the necessity for that protection to be truly effective and from the risk that, consequently, the legal entity subject to compliance with that norm must assume.” (the underlining is ours)

For all the above reasons, the present allegation is dismissed.

“SECOND.- Regarding the Agreement to Initiate Sanctioning Procedure and the infringements proposed by the AEPD”

Regarding the Agreement to Initiate Sanctioning Procedure and the infringements established by this Agency, GEOPOST considers that in this case, given a single conduct (the delivery person incorrectly affixed the label of the parcel on the outside of the mailbox), there would be no possibility of committing a violation of Article 5.1 f) without also committing a violation of Article 32 of the GDPR, since Article 32 of the GDPR is a more specific and detailed specification of the general principle established in Article 5.1 f) of the GDPR, for which it requests that, in the event that a violation by GEOPOST is appreciated, Article 29.5 of the LRJSP be applied, which states: “When the commission of an infringement results in...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/23

the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed.”

Well, the guarantee of confidentiality and the security of processing is fundamentally reflected in two independent provisions of the GDPR: in Article 5.1.f) and in Article 32 of the GDPR, respectively.

Article 5.1.f) of the GDPR encompasses the principle of integrity and confidentiality and stipulates that personal data shall be processed in such a way as to ensure an adequate level of security for personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of technical or organizational measures.

On the other hand, Article 32 of the GDPR establishes how security of processing should be articulated in relation to the specific security measures that must be implemented, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probabilities and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk that includes, among other things, the ability to ensure the confidentiality of the data.

From the examination of the proven facts and the documentation in the file, two infringements based on different facts and grounds can be clearly differentiated. Below, it is specified which conduct constitutes an infringement of Article 5.1.f) of the GDPR and which constitutes an infringement of Article 32 of the GDPR:

A) Infringement of Article 5.1.f) of the GDPR.

As we can see, Article 5.1.f) of the GDPR explicitly requires that confidentiality and integrity be guaranteed and requires a loss of confidentiality and/or integrity for its attribution. We may encounter situations where there are inadequate measures without there being a loss of integrity and confidentiality.

The European legislator has imposed an obligation of result in guaranteeing compliance with this principle.

Furthermore, Article 5.1.f) of the GDPR refers to the application of appropriate technical or organizational measures without restricting it to security technical or organizational measures. The measures referenced in Article 5.1.f) of the GDPR can be of all kinds, encompassing all those that serve to guarantee confidentiality and integrity.

In the present case, the confidentiality of the personal data of the claimant has not been guaranteed, which constitutes an infringement of Article 5.1.f) of the GDPR, since the delivery person left personal data of the claimant visible to any neighbor or visitor of the property, specifically, their name and surname, postal address, as well as their phone number, which were seen, at least, by the individuals who informed the claimant that the label was stuck on their mailbox when they were absent from their home.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
10/23

B) Violation of Article 32 of the GDPR.

The proven facts in the procedure demonstrate that the party being complained about exposed personal information and data by leaving a notice of absence attached to the outside of the claimant's mailbox (on which only the number and letter of the floor were indicated), in which her personal data appeared: name, surname, postal address, as well as her phone number.

It is evident that there has been a breach of technical and organizational measures, as GEOPOST is responsible for making decisions aimed at effectively implementing the appropriate technical and organizational measures to ensure an adequate level of security relative to the risk to guarantee the confidentiality of the data, restoring its availability and preventing access to it in the event of a physical or technical incident, as required by Article 32 of the GDPR.

From all of this, a lack of due diligence is inferred both in the compliance with the established security measures, as well as in the supervision or verification of their observance and/or suitability. In this regard, it is noted that Article 32 of the GDPR is violated both if the data controller does not adopt the appropriate technical and organizational measures that guarantee the security of personal data, and if, once established, these measures are not observed.

That said, Article 32.1 establishes an obligation of means and not an obligation of result. Indeed, it states that “the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk,” that is to say, it imposes the obligation to establish a level of security, and that level must be based on the risk analysis that every controller must carry out in accordance with paragraph 2 of that article:

“2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss or alteration of personal data transmitted, stored or otherwise processed, or the unauthorized communication or access to such data.”

The technological evolution and sophistication of unauthorized access systems to data systems mean that the regulation cannot unconditionally impose a total assurance of the absence of breaches of integrity or confidentiality.

However, it does require that data controllers must conduct a risk analysis and implement an “adequate level of security” accordingly.

Therefore, this duty is characterized as an obligation of means. This has been declared by the Supreme Court in its recent ruling of February 15, 2022:

“The obligation to adopt the necessary measures to ensure the security of personal data cannot be considered an obligation of result, which implies that if a leak of personal data to a third party occurs, there is liability regardless of the measures adopted and the activity carried out by the data controller or processor.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
11/23

In obligations of means, the commitment undertaken is to adopt the technical and organizational means, as well as to deploy diligent activity in their implementation and use, aimed at achieving the

expected result with means that can reasonably be classified as suitable and sufficient for its attainment; hence, they are referred to as "obligations of diligence" or "behavioral obligations." The difference lies in the responsibility in each case, as while in the obligation of result one is liable for a harmful outcome due to the failure of the security system, regardless of its cause and the diligence used, in the obligation of means it is sufficient to conduct a risk analysis, establish technically adequate measures, implement them correctly, and use them with reasonable diligence. In these latter cases, the sufficiency of the security measures that the responsible party must establish must be related to the state of technology at each moment and the level of protection required concerning the personal data processed, but a result is not guaranteed. As established in Article 31 of Regulation (EU) 2016/679 of the European Parliament and of the Council regarding the protection of natural persons concerning the processing of personal data and the free movement of such data, which repeals Directive 95/46/EC, it is stated regarding the security of processing that the appropriate technical and organizational measures are "Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons [...]."

We have already reasoned that the obligation imposed on the data controller regarding the adoption of necessary measures to ensure the security of personal data is not an obligation of result but of means, without the infallibility of the adopted measures being required. Only the adoption and implementation of technical and organizational measures, which according to the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow for the prevention of alteration, loss, unauthorized processing, or access is required. Having established the above, the obligation of means imposed by Article 32 of the GDPR consists of adopting security measures in processing, aimed at preventing the occurrence of a personal data breach therein. These obligations must be established based on the risks that have been analyzed, taking into account the state of technology at each moment and the level of protection required concerning the personal data processed.

For all the above reasons, this allegation is dismissed.

"THIRD.- Regarding the alleged infringement of Article 5.1 f) of the GDPR and/or Article 32 of the GDPR indicated by the AEPD"

In this allegation, GEOPOST argues that it has adopted adequate measures (protocols, periodic training plan...) based on the risk.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
12/23

In response to this argument, GEOPOST's commitment to compliance with current data protection regulations, ensuring the security and confidentiality of personal data processing through the application of technical and organizational security measures, while reflecting a positive conduct, does not alter the established facts.

For all the above reasons, this allegation is dismissed.

"FOURTH.- Regarding the classification of the infringement and the possible sanction to be imposed by the AEPD."

GEOPOST considers that the amount of the sanction is excessive; on one hand, regarding the aggravating factors, the volume of orders managed by GEOPOST has not been taken into account, and it is an exceptional event; on the other hand, a series of mitigating factors have not been evaluated, such as the absence of intent, due diligence, or GEOPOST's prompt action.

In contrast to what GEOPOST has expressed, it is important to highlight regarding the classification of the infringements and the sanctions set forth in the initiation agreement, that Article 83.5 of the GDPR establishes that the infringement of Article 5 of the GDPR may be sanctioned "with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount," which already applies a significant reduction of this.

The Supreme Court, Chamber 3, in its ruling of December 16, 2003 (Rec. 4996/98) already indicated that the principle of proportionality of sanctions requires that "the discretion granted to the Administration for the application of the sanction be developed by weighing in all cases the concurrent circumstances, in order to achieve the necessary proportionality between the alleged facts and the responsibility required." This principle of proportionality is not considered violated, as the proposed sanction to the entity is deemed proportionate, based on the proven facts and the weighed concurrent circumstances, which are detailed later, taking into account, moreover, the maximum limit of the amount of sanctions established by Article 83.4 of the GDPR.

Regarding the claim that no mitigating circumstances have been considered, given that there are a series of behaviors on the part of GEOPOST that, under the interpretation criteria of Articles 83.2 of the GDPR and 76.2 of the LOPD, should have been taken into account as mitigating factors to appropriately calibrate the sanction proposed by the AEPD, it is worth noting that the GDPR expressly provides for the possibility of modulation, through the provision of fines that can be adjusted, in light of a series of circumstances of each individual case. All these circumstances have been taken into account when determining the sanction.

The entity in question is one that manages a large volume of deliveries and pickups of packages from clients whose personal data is systematically processed in the exercise of its duties. This circumstance determines a greater

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/23

degree of demand and professionalism and, consequently, of responsibility of the entity in relation to the processing of personal data.

Consequently, the arguments presented do not undermine the essential content of the infringement declared to have been committed nor do they constitute sufficient justification or exculpation.

For all the above, the present allegation is dismissed.

B) Regarding the allegations made against the proposed resolution of this sanctioning procedure, a response is provided:

"First and only.- Infringement of the right to defense due to the absence of evidence of the facts attributed."

According to GEOPOST, it cannot be asserted, without reasonable doubt, that it was the delivery person of this company who left a note attached to the mailbox of the complaining party with their personal data, as it could have been attached to the mailbox by a third party. It adds that the complaint was initiated by an indirect witness, without the complaining party stating in their complaint to the AEPD that it was the delivery person of the Company who attached the document to their mailbox. In short, to the extent that the authorship of the act that gave rise to the present procedure is not proven, the violation of the right to defense is evident, as no evidence was presented to substantiate these facts.

In response to the argument put forth by GEOPOST, which questions who left the note attached to the mailbox of the complaining party, it is stated in the Third Proven Fact of this resolution that, in response to the transfer of the complaint dated October 17, 2022, made by this Agency, GEOPOST sent a response on November 14, 2022, in which it states: "...after receiving this information request, SEUR, S.A. has proceeded to investigate the events that occurred and has verified the following:

- That on August 30, 2022, a delivery person from SEUR, S.A. went to the residence of the complaining party to carry out a pickup.
- That the complaining party was absent at the time of the pickup.
- That, consequently, the delivery person left an absence notice attached to the exterior of the complaining party's mailbox." (the underlining is ours)

As can be seen, in the very response sent by GEOPOST regarding the transfer of the complaint, it attributed, according to its own investigations, to the delivery person of this company the act of leaving the notice (as it is literally named in their writing) attached to the exterior of the mailbox of the

complaining party. Furthermore, these facts were ratified in the allegations to the initiation agreement presented by GEOPOST:

“As reported in the response letter, the delivery person from SEUR went to the residence of the complaining party to carry out a pickup, but the complaining party was absent at the time of the pickup, so, consequently, the delivery person attached the package label to the exterior of the complaining party's mailbox, as can be seen in the...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/23

images included in the claim, bypassing the instructions and internal protocols of SEUR” (the underlining is ours).

On the other hand, GEOPOST must preserve the confidentiality of its clients' data, so that, in the event that the note, as GEOPOST suggests, may have been attached by a third party in the mailbox of the claiming party, it also implies the existence of liability attributable to GEOPOST, since the fact that an unauthorized third party accessed the personal data of the claiming party by being in possession of the sticky note or label constitutes, in itself, a violation of the confidentiality of the claiming party's data, due to a lack of diligence in the custody of the sticky note. There is no reason that justifies that the sticky note with the personal data of the claiming party, which was held by the GEOPOST delivery person, could be in the hands of a third party, a label that was not going to be used, due to the impossibility of collecting the package that was to be returned, because of the absence of the claiming party at their home; an absence that was duly communicated as stated in Proven Fact One.

Regarding security measures, GEOPOST states that the sticky note with the claiming party's data was not a “notice of absence at home,” as such notices are usually sent to the client's email, but rather it is the label that is attached to the package in the event of a return pickup. GEOPOST does not justify that the technical and organizational measures are appropriate to ensure a level of security adequate to the risk, to protect the personal data of its clients existing on the return pickup labels of a package, which poses a risk to the rights and freedoms of individuals, as has been demonstrated in this case.

Article 32 of the GDPR establishes how the security of processing should be articulated in relation to the specific security measures that must be implemented, so that taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks to the rights and freedoms of individuals, the controller and the processor shall apply appropriate technical and organizational measures to ensure a level of security appropriate to the risk that includes, among other issues, the ability to ensure the confidentiality of the data.

The Court of Justice of the European Union has ruled on the application of Article 32 of the GDPR in exercising its jurisdiction to rule, in a preliminary manner, on the validity and interpretation of acts adopted by the institutions, bodies, or agencies of the Union, in accordance with the provisions of Article 267 of the Treaty on the Functioning of the European Union. In a judgment dated December 14, 2023, in case C-340/21, it resolves a preliminary question raised by a judicial body regarding “whether the principle of accountability of the data controller, set out in Article 5, paragraph 2, of the GDPR and developed in Article 24 of the same, should be interpreted to mean that, ... the data controller bears the burden of proof of the appropriateness of the security measures it has adopted in accordance with Article 32 of the aforementioned Regulation,” establishing the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/23

"The wording of Articles 5(2), 24(1), and 32(1) of the GDPR unequivocally indicates that the burden of proof that personal data is processed in a manner that ensures an adequate level of security, in the sense of Articles 5(1)(f) and 32 of that Regulation, lies with the controller in question [see, by analogy,

the judgments of May 4, 2023, Bundesrepublik Deutschland (Judicial Electronic Mailbox), C-60/22, EU:C:2023:373, paragraphs 52 and 53, and of July 4, 2023, Meta Platforms and others (General Terms of Service of a Social Network), C-252/21, EU:C:2023:537, paragraph 95]."
(paragraph 52 of the judgment)

Consequently, in response to the transfer of the complaint, GEOPOST stated that the notice was affixed by the delivery person and, in any case, GEOPOST is responsible for ensuring that its customers' data is not made available to unauthorized third parties. Regarding the application of technical and organizational measures adopted by GEOPOST in the collection of packages subject to return, it has been demonstrated in this case that they do not guarantee an adequate level of security against the risk of protecting the personal data of its customers (name, surname, address, and phone number) present on the return package collection labels. Therefore, the first measure to be considered by GEOPOST is, taking into account the state of the art and the costs of implementation, whether it is necessary for all these personal data of its customers to be included on the return package collection stickers.

For all the above reasons, this allegation is dismissed.

IV

Principle of Confidentiality

Article 5(1)(f), "Principles relating to processing," of the GDPR states:

"1. Personal data shall be:

a) (...)

f) processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality')."

In relation to this principle, Recital 39 of the aforementioned GDPR states:

"[...] Personal data must be processed in a manner that ensures an adequate level of security and confidentiality of personal data, including to prevent unauthorized access or use of such data and the equipment used for processing."

The documentation in the file provides clear evidence that the respondent violated Article 5(1)(f) of the GDPR, principles relating to processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/23

In this case, it is noted that the personal data of the complainant, such as their name, surname, postal address, and phone number contained in the notice affixed to the outside of the mailbox, were improperly exposed to third parties, violating the principle of confidentiality, especially since only the number and letter of the floor were indicated on the mailbox label.

In accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement attributable to GEOPOST for violating Article 5(1)(f) of the GDPR.

V

Classification of the infringement of Article 5(1)(f) of the GDPR

The aforementioned infringement of Article 5(1)(f) of the GDPR constitutes one of the infringements classified in Article 83(5) of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Infringements of the following provisions shall be subject to administrative fines of up to EUR 20,000,000 or, in the case of an undertaking, an amount equivalent to 4% of the total annual global turnover of the preceding financial year, whichever is higher:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements," establishes that

"Infringements are constituted by acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law."

For the purposes of the limitation period, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. Based on what is established in Article 83(5) of Regulation (EU) 2016/679, infringements that constitute a substantial violation of the articles mentioned therein are considered very serious and shall be subject to a limitation period of three years, particularly the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VI

Obligation not fulfilled. Data Security.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/23

Article 32 of the GDPR establishes the following regarding the security of processing:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law."

From the documentation in the file, there is clear evidence that the respondent has violated Article 32 of the GDPR, as a security incident occurred by revealing personal information and data to third parties, when a delivery person left an absent notice stuck on the outside of the complainant's mailbox, which displayed her personal data: name, surname, postal address, as well as her phone number, visible to any neighbor or visitor to the property, when additionally the label on the mailbox only indicated the number and letter of the apartment.

As stated in the response letter dated November 14, 2022, the respondent believes that the incident occurred as a result of an error by the delivery person, who should have left the notice inside the mailbox or under the door as indicated by the GEOPOST manual and not stuck on the outside of the mailbox. In this regard, it should be noted that security measures must be adopted in consideration of each and every risk present in the processing of personal data, including the human factor.

C/ Jorge Juan, 6

www.aepd.es

It should be noted that the GDPR in the cited provision does not establish a list of security measures applicable according to the data being processed, but rather states that the data controller and the processor shall apply technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of the technical and organizational measures must be made considering: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, and the process of verification (which is not an audit), evaluation, and assessment of the effectiveness of the measures.

In any case, when assessing the adequacy of the level of security, particular attention shall be paid to the risks presented by the data processing, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial damage.

In this same sense, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the risks inherent in the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected.

When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly susceptible to causing physical, material, or immaterial damage.”

The responsibility of the respondent is determined by the breach of the technical and organizational measures, as they are responsible for making decisions aimed at effectively implementing the appropriate technical and organizational measures to ensure an adequate level of security relative to the risk to ensure the confidentiality of the data, restoring its availability and preventing access to it in the event of a physical or technical incident.

In accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement, attributable to GEOPOST, for violation of Article 32 of the GDPR.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

19/23

VII

Classification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes one of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to 2% of the total annual global turnover of the preceding financial year, whichever is higher:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and conduct

referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a limitation period of two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

g) The breach, as a result of a lack of due diligence, of the technical and organizational measures that should have been implemented in accordance with the requirements of Article 32.1 of Regulation (EU) 2016/679.”

VIII

Sanctions to be imposed

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 is, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each case.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/23

individual case, as an additional or substitute measure to those contemplated in Article 58, paragraph 2, letters a) to h) and j). When deciding on the imposition of an administrative fine and its amount in each individual case, the following will be duly taken into account:

- a) the nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damages they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the data controller or processor to mitigate the damages suffered by the affected parties;
- d) the degree of responsibility of the data controller or processor, considering the technical or organizational measures they have applied under Articles 25 and 32;
- e) any previous infringement committed by the data controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, particularly whether the data controller or processor reported the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the data controller or processor in relation to the same matter, compliance with those measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42;
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

For its part, Article 76 “Sanctions and corrective measures” of the LOPDGDD states:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.

- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the data controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any affected party."

Sanction for the infringement of Article 5.1.f) of the GDPR

In accordance with the transcribed provisions, for the purpose of determining the amount of the sanction for the infringement of Article 5.1 f) of the GDPR, the party claimed as responsible for the aforementioned infringement classified in Article 83.5 of the GDPR, it is appropriate to graduate the fine taking into account:

As an aggravating circumstance:

Article 76.2 b) LOPDGDD: "The connection of the infringer's activity with the processing of personal data"

It is a known fact that the party claimed is an entity that manages a large volume of deliveries and collections of customer packages whose personal data is systematically processed in the exercise of its duties.

This circumstance determines a greater degree of demand and professionalism and, consequently, of responsibility of the entity in relation to the processing of personal data.

As a mitigating circumstance:

Article 76.2.e) of the LOPDGDD: "The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity."

The merger by absorption process, in which GEOPOST ESPAÑA, S.L. (absorbing company) has merged with SEUR, S.A. (absorbed company), resulting in the extinction of the latter, allows for the application of this circumstance as a mitigating factor for the responsibility of the absorbing entity. Considering the factors presented, the assessment of the amount of the fine is €40,000.00 (forty thousand euros) for the infringement of Article 5.1 f) of the GDPR, regarding the breach of the principle of confidentiality.

Sanction for the infringement of Article 32 of the GDPR

In accordance with the transcribed provisions, for the purpose of determining the amount of the sanction for the infringement of Article 32 of the GDPR, the party claimed as responsible for the aforementioned infringement classified in Article 83.4 of the GDPR, it is appropriate to graduate the fine taking into account:

As an aggravating circumstance:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/23

Article 76.2 b) LOPDGDD: "The connection of the infringer's activity with the processing of personal data"

It is a well-known fact that the respondent is an entity that manages a large volume of deliveries and pickups of customer packages whose personal data is systematically processed in the exercise of its duties.

This circumstance determines a greater degree of demand and professionalism and, consequently, of responsibility of the entity in relation to the processing of personal data.

As a mitigating circumstance:

Article 76.2.e) of the LOPDGDD: "The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity."

The merger by absorption process, in which GEOPOST ESPAÑA, S.L. (absorbing company) has merged with SEUR, S.A. (absorbed company), resulting in the extinction of the latter, allows the application of this circumstance as a mitigating factor for the responsibility of the absorbing entity. Considering the factors presented, the assessment of the amount of the fine is €15,000.00 (fifteen thousand euros) for the infringement of Article 32 of the GDPR, regarding the lack of diligence in implementing appropriate security measures.

Therefore, in accordance with the applicable legislation and evaluated the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on GEOPOST ESPAÑA, S.L., with NIF B85645349:

- For an infringement of Article 5.1.f) of the GDPR, classified in accordance with the provisions of Article 83.5 of the GDPR, an administrative fine of €40,000.00.
- For an infringement of Article 32 of the GDPR, classified in accordance with the provisions of Article 83.4 of the GDPR, an administrative fine of €15,000.00.

SECOND: TO NOTIFY this resolution to GEOPOST ESPAÑA, S.L.

THIRD: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right.

The sanctioned party is warned that they must comply with the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No. IBAN:

ES00-0000-0000-0000-0000-0000, opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A.

Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal.

If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with the documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not have knowledge of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension would be considered terminated.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es